

WIRELESS SECURITY · STUDENT REFERENCE

# Wi-Fi Pentesting

Wireless Encryption Protocols & the Aircrack-ng Suite

A Structured Guide for Authorized Security Testing & Learning

# Before You Begin

**Legal & Ethical Notice:** The techniques in this guide can intercept, decrypt, or disrupt wireless traffic. In almost every country, using them against a network without the explicit, documented permission of its owner is illegal (e.g. under computer misuse / unauthorized access laws). Only practice against:

- Your own home network and your own devices,
- A dedicated wireless lab you control (e.g. a spare router flashed for testing), or
- A network you have *written* authorization to test (a signed scope/rules-of-engagement document, as in a professional penetration test).

This guide is written for defensive understanding, certification study (Security+, CEH, OSCP-style wireless modules), and authorized red-team/blue-team exercises.

**How to use this guide:** Part 1 covers the encryption protocols themselves (what actually protects — or fails to protect — the air interface). Part 2 covers the Aircrack-ng tool suite used to audit those protocols. Part 3 is a complete terminology reference. Commands are shown exactly as typed at a Linux terminal with a compatible monitor-mode wireless adapter.

## Contents

|                                       |                                                          |
|---------------------------------------|----------------------------------------------------------|
| Part 1 — Wi-Fi Security Protocols     | WEP, WPA, WPA2, WPA3, WPS                                |
| Part 2 — The Aircrack-ng Suite        | airmon-ng, airodump-ng, aireplay-ng, aircrack-ng, others |
| Part 3 — Terminology Reference        | A-Z glossary                                             |
| Part 4 — Attack Catalog               | Mechanism, impact & mitigation per attack                |
| Part 5 — Practical Walkthrough        | End-to-end example audit                                 |
| Part 6 — Defensive Hardening Playbook | Protocol-by-protocol mitigation checklist                |
| Part 7 — Detection & Monitoring       | Spotting these attacks as a defender                     |

# Part 1 — Wi-Fi Security Protocols

Every Wi-Fi security protocol solves the same three problems: **authentication** (proving you're allowed to join), **confidentiality** (encrypting the data), and **integrity** (detecting tampering). They differ enormously in how well they do this.

## 1.1 WEP — Wired Equivalent Privacy (1997/1999)

| Attribute       | Detail                                                               |
|-----------------|----------------------------------------------------------------------|
| Cipher          | RC4 stream cipher                                                    |
| Key sizes       | 64-bit (40-bit key + 24-bit IV) or 128-bit (104-bit key + 24-bit IV) |
| Integrity check | CRC-32 (linear, not cryptographic — can be manipulated)              |
| Authentication  | Open System or Shared Key (challenge-response reveals keystream)     |
| Security rating | <b>Broken / Deprecated</b>                                           |

**Why it fails:** The 24-bit Initialization Vector (IV) is far too small and is sent in plaintext with every packet. On a busy network IVs repeat within hours, letting an attacker collect enough repeated-IV packets to statistically recover the RC4 key (the FMS and later PTW/KoreK attacks). CRC-32 is linear, so packets can be modified and re-checksummed without detection. WEP can typically be cracked in minutes with tens of thousands of captured IVs — no password guessing required.

**Study note:** WEP is retained in real deployments only through neglect. It appears in this guide purely as a historical/legacy baseline — any WEP network encountered on a real assessment should be flagged as a critical finding.

## 1.2 WPA — Wi-Fi Protected Access (2003)

| Attribute       | Detail                                                                   |
|-----------------|--------------------------------------------------------------------------|
| Cipher          | RC4 (same engine as WEP) wrapped by TKIP                                 |
| Key management  | TKIP (Temporal Key Integrity Protocol) — per-packet key mixing, rekeying |
| Integrity check | Michael MIC (cryptographic, replaces CRC-32)                             |
| Modes           | WPA-Personal (PSK) and WPA-Enterprise (802.1X/RADIUS)                    |
| Security rating | <b>Deprecated</b>                                                        |

WPA was a stop-gap: it reused WEP-era RC4 hardware but fixed the IV-reuse and integrity problems with TKIP and Michael. It is still vulnerable to the **Beck-Tews** and **Ohigashi-Morii** chopchop-style attacks that allow limited packet decryption/injection, and TKIP was formally deprecated by the Wi-Fi Alliance.

## 1.3 WPA2 (2004) — the long-standing standard

| Attribute              | Detail                                                                                       |
|------------------------|----------------------------------------------------------------------------------------------|
| Cipher                 | AES-CCMP (AES in Counter Mode with CBC-MAC), 128-bit                                         |
| Optional legacy cipher | TKIP (mixed-mode, discouraged)                                                               |
| Handshake              | 4-Way Handshake, derives the Pairwise Transient Key (PTK) from the Pairwise Master Key (PMK) |
| PSK derivation         | PMK = PBKDF2(passphrase, SSID, 4096 iterations, 256 bits)                                    |
| Modes                  | WPA2-Personal (PSK) and WPA2-Enterprise (802.1X/EAP/RADIUS)                                  |
| Security rating        | <b>Sound design, weak in practice</b>                                                        |

WPA2-CCMP itself has no practical cryptographic break. Its real-world weak point is the **4-Way Handshake** and the human-chosen passphrase:

- **Offline dictionary/brute-force attacks** — capture the 4-way handshake once, then guess passphrases offline at whatever speed your hardware allows (no rate limiting, since it's offline).
- **PMKID attack (2018)** — many routers include a PMKID in the very first EAPOL frame of the handshake, letting an attacker skip waiting for a client to associate; a single captured frame is enough to attempt offline cracking.
- **KRACK (Key Reinstallation Attack, 2017)** — forces reinstallation of an already-used nonce/key during the 4-way or group-key handshake, allowing packet replay/decryption/forgery on some implementations.

## 1.4 WPA3 (2018) — the current standard

| Attribute               | Detail                                                                                                                     |
|-------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Cipher                  | AES-CCMP (128-bit, Personal) or AES-GCMP-256 (192-bit security suite, Enterprise)                                          |
| Key exchange            | SAE — Simultaneous Authentication of Equals ("Dragonfly" handshake), replaces PSK 4-way for personal mode                  |
| Forward secrecy         | Yes — a captured session cannot be decrypted even if the passphrase is later learned                                       |
| Offline guessing        | Prevented by design — SAE requires interaction per guess, so brute-forcing must be online (and is rate-limited/detectable) |
| Open network protection | OWE (Opportunistic Wireless Encryption) encrypts "open" Wi-Fi without a password                                           |
| Security rating         | Current best practice                                                                                                      |

SAE fixes WPA2-PSK's core flaw: instead of both sides deriving a static PMK from the passphrase (which can be attacked offline once captured), SAE runs an interactive zero-knowledge-style exchange over the air for every connection, so an attacker only gets one guess per interaction and cannot meaningfully speed this up by capturing traffic. Known WPA3 weaknesses are narrower and implementation-specific — the **Dragonblood** research (2019) found timing/cache side channels and downgrade attacks in some early SAE implementations, since largely patched, plus transition-mode (WPA2/WPA3 mixed) configurations that can be forced back down to WPA2.

## 1.5 WPS — Wi-Fi Protected Setup (a common side door)

WPS lets a device join using an 8-digit PIN instead of the full passphrase. The design flaw: the PIN is verified as two halves (4 digits + 3 digits + 1 checksum digit), so the effective search space is roughly 11,000 combinations instead of 100,000,000 — brute-forceable in hours (the basis of the **Reaver/Bully** tools). WPS should be disabled regardless of which encryption protocol (WPA2/WPA3) is otherwise in use.

## 1.6 Quick Comparison

| Protocol | Cipher        | Key exchange          | Main weakness                      | Rating        |
|----------|---------------|-----------------------|------------------------------------|---------------|
| WEP      | RC4           | Static key + small IV | IV reuse → key recovery            | Broken        |
| WPA      | RC4/TKIP      | 4-Way Handshake       | Chopchop / Michael attacks         | Deprecated    |
| WPA2     | AES-CCMP      | 4-Way Handshake (PSK) | Offline dictionary attack, KRACK   | Legacy-strong |
| WPA3     | AES-CCMP/GCMP | SAE (Dragonfly)       | Downgrade / side-channel (patched) | Current       |

## Part 2 — The Aircrack-ng Suite

Aircrack-ng is a collection of command-line tools for assessing Wi-Fi network security: capturing frames, injecting packets, cracking keys, and creating fake access points. It requires a wireless adapter and driver that support **monitor mode** and, ideally, **packet injection**.

**Typical assessment flow:** `airmon-ng` (enable monitor mode) → `airodump-ng` (survey & capture) → `aireplay-ng` (accelerate handshake capture) → `aircrack-ng` / `hashcat` (recover the key).

### 2.1 airmon-ng — Monitor Mode Manager

Switches a wireless interface between managed (normal) mode and monitor mode, which allows the adapter to see all frames on a channel rather than only ones addressed to it.

#### Check for interfering processes

```
airmon-ng check
```

#### Kill processes that could interfere (NetworkManager, wpa\_supplicant)

```
airmon-ng check kill
```

#### Enable monitor mode on wlan0

```
airmon-ng start wlan0
```

This typically creates a new virtual interface such as `wlan0mon`.

#### Lock to a specific channel while starting

```
airmon-ng start wlan0 6
```

#### Return the interface to normal mode

```
airmon-ng stop wlan0mon
```

### 2.2 airodump-ng — Packet Capture & Recon

Captures raw 802.11 frames, lists nearby access points and connected clients, and writes capture files used later for cracking.

#### Survey all nearby networks

```
airodump-ng wlan0mon
```

Displays BSSID, power level (PWR), beacon count, data count, channel, encryption (WEP/WPA/WPA2/WPA3), cipher, authentication method, and ESSID for every visible AP, plus a client list below with which BSSID each client is associated to.

#### Target one AP, one channel, and write a capture file

```
airodump-ng --bssid AA:BB:CC:DD:EE:FF -c 6 -w capture wlan0mon
```

| Flag                         | Meaning                                                                                 |
|------------------------------|-----------------------------------------------------------------------------------------|
| <code>--bssid</code>         | Restrict capture to one access point's MAC address                                      |
| <code>-c</code>              | Lock capture to a specific channel                                                      |
| <code>-w</code>              | Write capture to disk with the given filename prefix (produces .cap/.csv/.kismet files) |
| <code>--output-format</code> | Choose output formats (pcap, csv, kismet, etc.)                                         |

### 2.3 aireplay-ng — Packet Injection & Deauthentication

Generates or replays traffic to speed up data collection — most commonly used to force a client to reauthenticate so its 4-way handshake can be captured.

### Send deauthentication frames to a client

```
aireplay-ng --deauth 10 -a AA:BB:CC:DD:EE:FF -c 11:22:33:44:55:66 wlan0mon
```

| Flag                            | Meaning                                                            |
|---------------------------------|--------------------------------------------------------------------|
| <code>--deauth &lt;n&gt;</code> | Number of deauth bursts to send (0 = continuous)                   |
| <code>-a</code>                 | Target AP's BSSID                                                  |
| <code>-c</code>                 | Target client's MAC address (omit to deauth broadcast/all clients) |

### Legacy WEP: ARP-replay attack to generate traffic

```
aireplay-ng --arpplay -b AA:BB:CC:DD:EE:FF -h 11:22:33:44:55:66 wlan0mon
```

### Fake authentication with an AP (needed before some injection attacks)

```
aireplay-ng --fakeauth 0 -a AA:BB:CC:DD:EE:FF wlan0mon
```

**Ethics note:** Deauthentication is a denial-of-service technique — it disconnects real users. Only send deauth frames against equipment you own or are explicitly authorized to test, and be aware it may violate telecom/spectrum regulations even on your own premises in some jurisdictions.

## 2.4 aircrack-ng — The Cracking Engine

Takes a capture file (with a handshake, for WPA/WPA2/WPA3, or enough IVs, for WEP) and recovers the key.

### Crack WPA/WPA2 with a wordlist

```
aircrack-ng -w rockyou.txt -b AA:BB:CC:DD:EE:FF capture-01.cap
```

### Crack legacy WEP (statistical attack, no wordlist needed)

```
aircrack-ng -b AA:BB:CC:DD:EE:FF capture-01.cap
```

| Flag            | Meaning                                                   |
|-----------------|-----------------------------------------------------------|
| <code>-w</code> | Path to a wordlist for dictionary-based WPA/WPA2 attacks  |
| <code>-b</code> | Target BSSID inside a capture file with multiple networks |
| <code>-e</code> | Target by ESSID (network name) instead of BSSID           |

## 2.5 airbase-ng — Rogue / Fake Access Point

Turns a wireless card into an access point, used to build evil-twin honeypots for client testing or to capture handshakes by luring clients to reconnect.

```
airbase-ng -e "Free_WiFi" -c 6 wlan0mon
```

## 2.6 airdecap-ng — Decrypting Captures

Decrypts a .cap file once the key (or WEP key) is known, producing a plaintext capture that can be opened in Wireshark for traffic analysis.

```
airdecap-ng -p PassphraseHere -e MyNetworkSSID capture-01.cap
```

## 2.7 Supporting & Related Utilities

| Tool        | Purpose                                                 |
|-------------|---------------------------------------------------------|
| airmon-ng   | Enable/disable monitor mode, list interfaces & chipsets |
| airodump-ng | Passive capture & wireless recon                        |
| aireplay-ng | Active packet injection: deauth, ARP replay, fake auth  |

|                |                                                                     |
|----------------|---------------------------------------------------------------------|
| aircrack-ng    | Offline key recovery (WEP statistical / WPA-WPA3 dictionary)        |
| airbase-ng     | Software access point / rogue AP creation                           |
| airdecap-ng    | Decrypt a capture once the key is known                             |
| airolib-ng     | Precompute and store PMK hash tables for faster repeated cracking   |
| packetforge-ng | Craft custom encrypted packets for injection (WEP)                  |
| besside-ng     | Automates the deauth → capture → crack cycle across all visible APs |
| wesside-ng     | Automated WEP-only key recovery                                     |
| tkiptun-ng     | Proof-of-concept WPA/TKIP packet injection                          |
| easside-ng     | Communicate with a WEP AP without knowing the key (session tool)    |

## 2.8 Complementary Tools Often Paired with Aircrack-ng

| Tool                        | Purpose                                                                     |
|-----------------------------|-----------------------------------------------------------------------------|
| hashcat                     | GPU-accelerated offline cracking of captured handshakes/PMKIDs (mode 22000) |
| hcxdumptool / hcxpcapngtool | Capture and convert to the PMKID/handshake format hashcat expects           |
| Wireshark                   | Deep frame-by-frame inspection of decrypted captures                        |
| Reaver / Bully              | WPS PIN brute-force attacks                                                 |
| Kismet                      | Passive wireless IDS / long-term network discovery                          |
| Wifite                      | Automation wrapper that scripts the aircrack-ng workflow                    |

# Part 3 — Terminology Reference

---

## Access Point (AP)

The hardware that bridges wireless clients to a wired network; broadcasts the network's beacon frames.

## AES (Advanced Encryption Standard)

Block cipher used by WPA2/WPA3 (in CCMP/GCMP modes) to encrypt frame payloads.

## Beacon Frame

Management frame an AP broadcasts periodically, announcing its SSID, supported rates, and security settings.

## BSSID

The MAC address of a specific access point's radio — uniquely identifies one AP, distinct from the network name (SSID).

## CCMP

Counter Mode with CBC-MAC Protocol — the AES-based encryption/integrity mode used by WPA2.

## Channel

A specific frequency slice within the 2.4 GHz or 5/6 GHz bands that an AP transmits on.

## Deauthentication Frame

A management frame (unauthenticated by design in older standards) that forces a client to disconnect from an AP; used to trigger handshake recapture.

## Dictionary Attack

Trying candidate passwords from a wordlist against a captured hash, rather than every possible combination.

## EAPOL (EAP over LAN)

The frame type used to carry the 4-Way Handshake messages between client and AP.

## ESSID / SSID

The human-readable network name (e.g. "HomeWiFi-5G").

## 4-Way Handshake

The four-message exchange in WPA/WPA2 that proves both sides know the PMK and derives a fresh session key (PTK) without ever sending the key itself over the air.

## GCMP

Galois/Counter Mode Protocol — AES mode used in WPA3's 192-bit enterprise security suite.

## Handshake Capture

A .cap file containing the 4 EAPOL frames (or PMKID) needed to attempt offline key recovery.

## Injection

Sending crafted 802.11 frames onto the air rather than only listening — requires driver/firmware support.

## IV (Initialization Vector)

A value mixed with the key to vary the keystream per packet; WEP's 24-bit IV was its fatal weakness.

## Monitor Mode

A wireless adapter mode that captures all 802.11 frames on a channel, not just those addressed to the adapter, and without needing to be associated to an AP.

## MIC (Message Integrity Check)

A cryptographic check (Michael in WPA, part of CCMP/GCMP in WPA2/3) that detects tampering, replacing WEP's weak CRC-32.

## Nonce

A "number used once" mixed into key-derivation/encryption to ensure the same input never produces the same output twice; central to both the 4-way handshake and KRACK.

## OWE (Opportunistic Wireless Encryption)

WPA3 feature that encrypts traffic on "open" networks without requiring a shared password.

## PBKDF2

Password-Based Key Derivation Function 2 — used in WPA/WPA2 to stretch the passphrase and SSID into the PMK via 4096 rounds of hashing.

## PMK (Pairwise Master Key)

The long-term key derived from the passphrase (Personal) or from 802.1X/EAP authentication (Enterprise); the seed for session keys.

## PMKID

A hash derived from the PMK, sent in the first EAPOL frame by many routers; lets an attacker attempt offline cracking from a single captured frame instead of a full handshake.

## PTK (Pairwise Transient Key)

The session key derived per-connection from the PMK plus nonces from both sides during the 4-way handshake; actually encrypts unicast traffic.



### **RC4**

The stream cipher used by WEP and (wrapped in TKIP) by WPA; considered cryptographically broken for Wi-Fi use.

### **Rogue AP / Evil Twin**

An attacker-controlled access point mimicking a legitimate one's SSID, used to intercept clients that connect to it by mistake.

### **SAE (Simultaneous Authentication of Equals)**

The "Dragonfly" key-exchange protocol WPA3-Personal uses instead of a static PSK-derived PMK; provides forward secrecy and resists offline guessing.

### **TKIP (Temporal Key Integrity Protocol)**

WPA's key-mixing/rekeying scheme layered over RC4 to patch WEP's flaws without new hardware; itself now deprecated.

### **Wordlist**

A text file of candidate passwords (e.g. rockyou.txt) fed to a cracking tool for dictionary attacks.

### **WPS (Wi-Fi Protected Setup)**

A convenience PIN/button pairing mechanism, frequently vulnerable to brute-force due to weak PIN validation design.

# Part 4 — Attack Catalog

Each entry below follows the same structure: what the attack targets, how it actually works, what an attacker gains, and how to mitigate or detect it. These are the attacks the Part 2 tools are used to demonstrate.

## 4.1 WEP IV Collision / Statistical Key Recovery

|            |                                                                                                                                                                                                                                              |
|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Targets    | WEP                                                                                                                                                                                                                                          |
| Mechanism  | The 24-bit IV is transmitted in plaintext and reused constantly on a busy network. Once enough packets share (or nearly share) an IV, the RC4 keystream bias lets statistical attacks (FMS, KoreK, PTW) recover the key without guessing it. |
| Tools      | airodump-ng (capture), aireplay-ng --arpreplay (force traffic to generate more IVs faster), aircrack-ng (recovery)                                                                                                                           |
| Impact     | Full key recovery, typically in minutes with 20,000–40,000+ captured IVs.                                                                                                                                                                    |
| Mitigation | Retire WEP entirely — there is no configuration fix. Migrate to WPA2-CCMP or WPA3-SAE.                                                                                                                                                       |

## 4.2 WPA/WPA2 Offline Dictionary Attack on the 4-Way Handshake

|            |                                                                                                                                                                                                                                                                               |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Targets    | WPA, WPA2-Personal                                                                                                                                                                                                                                                            |
| Mechanism  | An attacker captures the 4-way handshake (or forces one via deauth), then computes PBKDF2(candidate_passphrase, SSID) offline for every wordlist entry and compares against the captured MIC — no further contact with the AP is needed, so there's no lockout or rate limit. |
| Tools      | aireplay-ng --deauth (trigger handshake), airodump-ng (capture), aircrack-ng / hashcat mode 22000 (crack)                                                                                                                                                                     |
| Impact     | Recovers the plaintext passphrase if it exists in (or is derivable from) the wordlist; success is entirely a function of passphrase entropy and attacker compute (GPU cracking rigs test billions of candidates/second).                                                      |
| Mitigation | Long, high-entropy passphrase (16+ random characters or a multi-word passphrase); move to WPA3-SAE where offline guessing is not possible even after capture.                                                                                                                 |

## 4.3 PMKID Attack (Handshake-less Capture)

|            |                                                                                                                                                                                                                                                                                           |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Targets    | WPA2-Personal (many consumer routers), some WPA3-transition modes                                                                                                                                                                                                                         |
| Mechanism  | Many APs include a PMKID (a hash of the PMK, AP MAC, and station MAC) in the very first EAPOL message they send. An attacker can request this directly via a fake-authentication association attempt, without ever waiting for a real client to connect or sending a single deauth frame. |
| Tools      | hcxdumpool, hcxcapngtool, hashcat mode 16800/22000                                                                                                                                                                                                                                        |
| Impact     | Same outcome as 4.2 (offline dictionary cracking) but silent — no deauth traffic, so it evades detection methods that watch only for deauth floods.                                                                                                                                       |
| Mitigation | Same as 4.2 (passphrase entropy / WPA3-SAE); some vendors have released firmware that disables PMKID caching by default — check for updates.                                                                                                                                              |

## 4.4 KRACK — Key Reinstallation Attack

|            |                                                                                                                                                                                                                                                                                                                           |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Targets    | WPA2 (protocol-level flaw in the 4-way and group-key handshakes, patchable in software)                                                                                                                                                                                                                                   |
| Mechanism  | By replaying message 3 of the 4-way handshake (often via a man-in-the-middle position), a client can be tricked into reinstalling an already-used encryption key, resetting its nonce/replay counters to their initial values. This allows packet replay, decryption, and in some configurations forged packet injection. |
| Tools      | Originally a proof-of-concept research toolkit (not part of aircrack-ng); understanding it matters for patch verification during an assessment.                                                                                                                                                                           |
| Impact     | Traffic decryption/injection on vulnerable clients or APs (severity varied heavily by implementation — some Linux/Android stacks were hit hardest due to all-zero key reinstallation).                                                                                                                                    |
| Mitigation | Patch both AP firmware and client OS/drivers — nearly all major vendors shipped fixes in 2017–2018. Verify patch status on legacy IoT devices specifically, since they are frequently missed.                                                                                                                             |

## 4.5 Dragonblood — WPA3 SAE Side-Channel & Downgrade Attacks

|           |                                                                                                                                                                                                                                                                                                                   |
|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Targets   | Early WPA3 SAE implementations; WPA2/WPA3 "transition mode" (mixed) networks                                                                                                                                                                                                                                      |
| Mechanism | Two families: (1) timing/cache side-channel leaks during SAE's password-to-point encoding, letting an attacker recover partial information to speed offline guessing; (2) forcing a client that supports the WPA2/WPA3 transition mode to connect using WPA2 instead, then attacking the connection with 4.2/4.3. |

|            |                                                                                                                                      |
|------------|--------------------------------------------------------------------------------------------------------------------------------------|
| Tools      | Dragonslayer/Dragondrain (academic research tools); relevant to assessors mainly for testing whether patches are applied.            |
| Impact     | Passphrase recovery on unpatched SAE implementations, or forced downgrade to a weaker protocol.                                      |
| Mitigation | Update AP firmware (most vendors patched by 2020); disable WPA2/WPA3 transition mode and run WPA3-only where all clients support it. |

## 4.6 Deauthentication / Disassociation Flood (DoS)

|            |                                                                                                                                                                                     |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Targets    | All protocols (WEP through WPA2; largely mitigated by 802.11w in WPA3)                                                                                                              |
| Mechanism  | Management frames (deauth/disassoc) were historically unauthenticated, so anyone in radio range can forge them as if sent by the AP or client, repeatedly kicking a device offline. |
| Tools      | aireplay-ng --deauth, mdk4                                                                                                                                                          |
| Impact     | Denial of service; also used as a stepping stone to force handshake recapture (see 4.2) or push a user toward an evil-twin AP (see 4.7).                                            |
| Mitigation | Enable 802.11w (Protected Management Frames / PMF) — mandatory in WPA3, optional in WPA2 on supporting hardware — which cryptographically signs management frames.                  |

## 4.7 Evil Twin / Rogue Access Point

|            |                                                                                                                                                                                                                                                                                                                                              |
|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Targets    | Clients, regardless of the legitimate network's protocol                                                                                                                                                                                                                                                                                     |
| Mechanism  | An attacker broadcasts an AP with the same SSID as a legitimate network (often at higher signal strength, sometimes after deauthing clients off the real AP), so devices with saved-network auto-connect settings join it instead. Traffic can then be logged, a captive portal can phish credentials, or a downstream MITM attack launched. |
| Tools      | airbase-ng, hostapd-based rogue AP toolkits                                                                                                                                                                                                                                                                                                  |
| Impact     | Credential capture, traffic interception, malware delivery via fake captive portals.                                                                                                                                                                                                                                                         |
| Mitigation | Use WPA2/WPA3-Enterprise with certificate-based (EAP-TLS) authentication so clients cryptographically verify the network, not just the SSID; user training against auto-joining open "free wifi" networks; wireless intrusion detection (WIDS) to flag duplicate SSIDs/BSSID anomalies.                                                      |

## 4.8 WPS PIN Brute Force (Pixie Dust & Online)

|            |                                                                                                                                                                                                                                                                            |
|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Targets    | Any AP with WPS enabled, regardless of WPA/WPA2/WPA3                                                                                                                                                                                                                       |
| Mechanism  | The 8-digit WPS PIN is validated in two halves, cutting the real search space to roughly 11,000 combinations (online brute force). "Pixie Dust" goes further, exploiting poor random-number generation in some chipsets to compute the PIN offline from a single exchange. |
| Tools      | Reaver, Bully                                                                                                                                                                                                                                                              |
| Impact     | Full passphrase recovery regardless of how strong the actual Wi-Fi password is, since WPS reveals it once the PIN is known.                                                                                                                                                |
| Mitigation | Disable WPS entirely; if it cannot be disabled, replace the router with one that allows it.                                                                                                                                                                                |

## 4.9 Chopchop / Fragmentation Attacks (WPA-TKIP)

|            |                                                                                                                                                                                                                                                    |
|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Targets    | WPA-TKIP                                                                                                                                                                                                                                           |
| Mechanism  | Exploits TKIP's Michael MIC error-handling: an attacker can incrementally decrypt the last bytes of a packet by observing whether the AP flags a MIC failure, eventually recovering enough keystream to forge and inject small packets (e.g. ARP). |
| Tools      | aireplay-ng --chopchop, --fragment; tkiptun-ng                                                                                                                                                                                                     |
| Impact     | Limited packet decryption and injection — not full key recovery, but enough for traffic manipulation.                                                                                                                                              |
| Mitigation | Disable TKIP; use WPA2/WPA3 with AES-CCMP/GCMP only.                                                                                                                                                                                               |

## 4.10 Attack Summary Matrix

| Attack             | Protocol(s) | Attacker position          | Primary defense          |
|--------------------|-------------|----------------------------|--------------------------|
| IV collision       | WEP         | Passive/active nearby      | Retire WEP               |
| Offline dictionary | WPA/WPA2    | Passive capture            | Strong passphrase / WPA3 |
| PMKID              | WPA2        | Passive, no clients needed | Strong passphrase / WPA3 |
| KRACK              | WPA2        | MITM / on-path             | Patch firmware & OS      |

|                          |                               |                       |                                |
|--------------------------|-------------------------------|-----------------------|--------------------------------|
| Dragonblood              | WPA3 (early), transition mode | Passive/active nearby | Patch, disable transition mode |
| Deauth flood             | All except PMF-enabled        | Active nearby         | Enable 802.11w / PMF           |
| Evil twin                | All (SSID spoofing)           | Active nearby         | Enterprise EAP-TLS, WIDS       |
| WPS PIN / Pixie Dust     | Any (via WPS)                 | Active nearby         | Disable WPS                    |
| Chopchop / fragmentation | WPA-TKIP                      | Active nearby         | Disable TKIP, use AES-CCMP     |

## Part 5 — Practical Walkthrough (Authorized Lab Example)

---

This walkthrough assumes a lab AP you own, running WPA2-Personal, and a monitor-mode-capable adapter as `wlan0`.

### Step 1 — Prepare the adapter

```
sudo airmon-ng check kill
sudo airmon-ng start wlan0
```

### Step 2 — Discover the target network

```
sudo airodump-ng wlan0mon
```

Note the BSSID and channel of your lab AP, then press Ctrl+C.

### Step 3 — Capture on that network only

```
sudo airodump-ng --bssid AA:BB:CC:DD:EE:FF -c 6 -w lab_capture wlan0mon
```

### Step 4 — Encourage a handshake (deauth a connected test client)

```
sudo aireplay-ng --deauth 5 -a AA:BB:CC:DD:EE:FF -c 11:22:33:44:55:66 wlan0mon
```

Watch the airodump-ng window for "WPA handshake:" to confirm capture.

### Step 5 — Attempt offline recovery with a wordlist

```
aircrack-ng -w rockyou.txt -b AA:BB:CC:DD:EE:FF lab_capture-01.cap
```

### Step 6 — Restore the adapter

```
sudo airmon-ng stop wlan0mon
sudo systemctl restart NetworkManager
```

A successful crack demonstrates that the passphrase was weak enough to appear in (or be derivable from) the wordlist — the fix is a longer, higher-entropy passphrase or a move to WPA3-SAE, not a flaw you can patch in the protocol itself.

## Part 6 — Defensive Hardening Playbook

---

Mitigations grouped by layer, from protocol choice down to operational hygiene.

### 6.1 Protocol & Configuration

- Use **WPA3-Personal (SAE)** where every client supports it; run WPA2-CCMP (AES only, never TKIP) where mixed-client support is unavoidable.
- Avoid **WPA2/WPA3 transition (mixed) mode** long-term — it exists for migration, not as a permanent state, since it reopens WPA2-class attacks against any client that negotiates down.
- Disable **WPS** entirely; if the router cannot disable it in firmware, replace the router.
- Enable **802.11w (Protected Management Frames)** to stop deauth/disassoc forgery — mandatory under WPA3, optional (but available) on most modern WPA2 hardware.
- Disable legacy/rarely-used features that widen attack surface: WEP support, TKIP-only mode, and remote router administration over Wi-Fi.

### 6.2 Credentials & Identity

- Passphrase length beats complexity: a random 16–20+ character passphrase resists dictionary/GPU cracking far better than a short one with symbols swapped in ("P@ssw0rd1" is still weak).
- On enterprise networks, use **802.1X/EAP-TLS** with per-user or per-device certificates instead of a single shared PSK — this also lets you revoke one device without rotating the password for everyone.
- Rotate the PSK after any suspected exposure (departing employee, lost device, known handshake capture).

### 6.3 Network Architecture

- Segment guest, IoT, and corporate traffic onto separate SSIDs/VLANs, so a compromised passphrase on one segment doesn't expose the rest.
- Apply client isolation on guest/public networks so devices can't reach each other directly.
- Place IoT devices (often slow to receive security patches) on a restricted VLAN with limited outbound access.

### 6.4 Patching & Maintenance

- Keep AP/router firmware current to pick up fixes for KRACK, Dragonblood, and PMKID-caching behavior.
- Audit older or IoT client devices specifically — these are the most likely to still run unpatched, vulnerable Wi-Fi stacks years after a fix ships for mainstream OSes.
- Track vendor security advisories for your specific AP hardware/chipset rather than assuming "WPA3" alone means all known issues are closed.

# Part 7 — Detection & Monitoring

A defender doesn't need to wait to be attacked to notice most of Part 4's techniques — each leaves a detectable footprint.

| Attack                        | Detectable signature                                                                                                                                  | How to watch for it                                                                                                     |
|-------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| Deauth flood                  | Spike in deauth/disassoc management frames, often spoofing the AP's or a client's MAC                                                                 | Wireless IDS (Kismet, vendor WIDS); PMF adoption reduces the attack's viability, making forged frames rejected outright |
| Evil twin                     | Duplicate SSID broadcast from an unrecognized BSSID; sudden new AP on a channel not matching your inventory                                           | Maintain an authorized-BSSID inventory; WIDS BSSID/SSID correlation alerts                                              |
| PMKID / handshake capture     | Repeated authentication/association attempts from an unassociated client, or unusually frequent full 4-way handshakes without a real disconnect event | Monitor association/auth frame rates per client; unexplained handshake churn is a red flag even without deauth traffic  |
| WPS brute force               | Rapid sequential PIN attempts against the WPS registrar                                                                                               | Router-level WPS lockout/logging (many implementations lock out after repeated failures — check yours enforces this)    |
| Rogue AP inside your building | An AP visible only on internal wired-adjacent scans, not matching site survey records                                                                 | Periodic physical + RF site surveys; wired-side rogue-AP detection (looking for AP MACs appearing on the wired switch)  |

**Practical tip:** Most of these detections come "for free" from a properly configured WIDS/WIPS or from enterprise AP controllers (Cisco, Aruba, Ubiquiti, etc.) that already log deauth spikes, rogue APs, and abnormal association patterns — the main job for a defender is turning on and actually reviewing those logs.

**Summary:** WEP and WPA are broken by design and should never appear in production. WPA2 is sound cryptographically but leans on passphrase strength and up-to-date firmware — its main real-world risks are a weak password (dictionary/PMKID attacks) and unpatched KRACK exposure. WPA3's SAE handshake removes the offline-guessing problem entirely, provided transition mode is avoided and firmware is current. The Aircrack-ng suite is the classic toolchain for demonstrating exactly these gaps — every command in this guide is only lawful and ethical against networks you own or are authorized in writing to test.